WALKER PRESS

CompTIA Security+ SY0-701

Practice Exam 4 of 5

90 Questions | 90 Minutes | Passing score 750 on a scale of 100–900

• This practice exam mirrors the format of the CompTIA Security+ SY0-701 certification exam: a maximum of 90 questions in 90 minutes.
• CompTIA reports the passing score as 750 on a scale of 100 to 900. That scale is CompTIA's own and is not a percentage of correct answers, so this document does not print a pass mark of its own. Use the Answer Key to find the objectives that need another evening.
• Questions are weighted by domain as on the real exam: General Security Concepts 12%, Threats, Vulnerabilities, and Mitigations 22%, Security Architecture 18%, Security Operations 28%, Security Program Management and Oversight 20%.
• Question types include Multiple Choice, Select Two/Three, Matching and Ordering. For Matching questions, pair each item with the best description. For Ordering questions, arrange the items in the correct sequence.
• The Answer Key with a full explanation for every question is at the end of this document.

www.walker-press.com

Questions

Question 1 [Multiple Choice]

Nadia is deploying an inline network security appliance. She must ensure that if the appliance loses power or crashes, all traffic through it is blocked until the device is restored. Which failure mode should she configure?

A. Fail-closed
B. Tap/monitor mode
C. Fail-open
D. Passive operation

Question 2 [Multiple Choice]

Which policy defines the actions users may perform while accessing systems and networking equipment?

A. AUP
B. MOU
C. NDA
D. SLA

Question 3 [Matching]

Match each identity type to its characteristic.

Items	Descriptions
1. Service account	**A.** Used by applications or scripts
2. Privileged user	**B.** Limited, temporary access
3. Standard user	**C.** Elevated permissions and higher risk
4. Guest account	**D.** Basic access for daily tasks

Question 4 [Multiple Choice]

Which of the following controls is specifically designed to identify a security breach after it has occurred?

A. MFA
B. Password policy
C. IDS
D. Firewall

Question 5 [Multiple Choice]

A company wants to detect signs of internal employees exfiltrating sensitive data over time. Which tool would be most effective?

A. UEBA
B. Firewall
C. Load balancer
D. SIEM

Question 6 [Multiple Choice]

Which of the following is a PRIMARY goal of business continuity planning?

A. Limit user permissions
B. Monitor encrypted traffic
C. Protect physical buildings
D. Maintain operations during a disruption

Question 7 [Multiple Choice]

Which of the following is NOT a reason that threat actors use PowerShell for attacks?

A. It is installed by default on many Windows systems.
B. It can execute commands in memory, reducing the need to write payload files to disk.
C. It can execute before any operating system environment has loaded.
D. It is a legitimate administrative tool that security controls may trust or allow.

Question 8 [Multiple Choice]

A regional bank repeatedly failed to meet the data protection requirements set by its financial regulator. After a formal examination, the regulator revoked the bank's authorization to operate in the jurisdiction. Which consequence of non-compliance has the bank experienced?

A. Sanctions
B. Contractual impacts
C. Loss of license
D. Fines

Question 9 [Multiple Choice]

Fill in the blank: The _____ determines how long an organization can tolerate a system outage.

A. MTTR (Mean Time To Repair)
B. RTO (Recovery Time Objective)
C. MTBF (Mean Time Between Failures)
D. RPO (Recovery Point Objective)

Question 10 [Ordering]

A contractor's laptop is confirmed to be running a keylogger that is beaconing to an external host. The team must contain the compromise, clean the device, and return it to service. Arrange the actions in the order the team should take them.

Place the following in the correct order:

A. Capture a memory image and preserve logs before cleaning
B. Isolate the infected laptop from the network
C. Eradicate the malware and remove its persistence mechanisms
D. Restore the system from a known-good backup
E. Monitor the device to confirm the threat does not return
F. Patch the exploited weakness and harden the configuration

Question 11 [Multiple Choice]

Bohdan is explaining to an intern some of the disadvantages to active scanning. Which of the following would Bohdan NOT give as a disadvantage?

A. Active scanning can accelerate the collection of data
B. Smaller networks can become overloaded with high volumes of test traffic
C. Sending test traffic increases the risk of the endpoints malfunctioning if incompatible queries are sent
D. IoT devices may react differently to test traffic

Question 12 [Multiple Choice]

An online retailer that serves customers in the European Union receives a request from a former customer to erase every record of personal data the company holds about them. The privacy team confirms that no legal retention obligation applies and schedules the deletion. Which privacy right is the retailer honoring?

A. The right to be forgotten
B. The right to data portability
C. The right to a data inventory
D. The right of ownership

Question 13 [Multiple Choice]

Fill in the blank: A user receives a fraudulent email that impersonates a legitimate organization and directs the user to a fake login page. This is a _____ attack.

A. Whaling
B. Smishing
C. Vishing
D. Phishing

Question 14 [Multiple Choice]

What is a key difference between SIEM and SOAR platforms?

A. SOAR collects logs; SIEM performs orchestration
B. SIEM automates response actions; SOAR only collects logs
C. SIEM aggregates and correlates logs; SOAR automates workflows
D. Both perform the same function

Question 15 [Multiple Choice]

Which of the following is NOT true about zero trust?

A. Zero trust is designed to make a system trusted.
B. Zero trust acknowledges that implicit trust is a vulnerability.
C. The motto of zero trust is "Never trust, always verify."
D. Zero trust assumes that networks have already been infiltrated by threat actors.

Question 16 [Matching]

Match each type of policy with its description.

Items	Descriptions
1. Acceptable Use Policy (AUP)	**A.** Outlines responsible use of IT resources
2. BYOD Policy	**B.** Limits personal device usage
3. Clean Desk Policy	**C.** Defines how long data is kept
4. Data Retention Policy	**D.** Ensures sensitive information is not left out

Question 17 [Ordering]

A newly hired security awareness manager is building the company's first awareness program. Arrange the program activities in the order they should be carried out.

Place the following in the correct order:

A. Track recurring metrics each quarter and update the content as threats change

B. Compile the initial report of phishing click rates and training completion percentages

C. Develop role-based training content and phishing simulation templates

D. Identify the audience groups and the threats the program must address

E. Deliver the training modules and launch the first phishing simulation campaign

Question 18 [Multiple Choice]

Which mitigation technique limits an attacker's ability to move between network zones after compromising one system?

A. Segmentation

B. Patching

C. Decommissioning

D. Encryption

Question 19 [Multiple Choice]

Analysts on the security team perform daily log reviews and run the incident-response procedure by hand whenever an alert fires. These are day-to-day activities carried out by people rather than by automated systems. Which control category do they best represent?

A. Operational

B. Technical

C. Physical

D. Managerial

Question 20 [Multiple Choice]

Which of the following is an example of a deterrent control?

A. Access badge with security camera

B. Data classification policy

C. Antivirus signature

D. Disk encryption

Question 21 [Multiple Choice]

Which regulation is primarily concerned with financial reporting integrity?

A. SOX

B. GDPR

C. PCI DSS

D. HIPAA

Question 22 [Select Two]

A vulnerability scan reports a critical remote code execution flaw on a server that controls a factory line. The vendor's patch will not be available for six months, and management has approved a documented exception. Which TWO actions will MOST reduce the risk while the exception remains open? (Select TWO.)

A. Deploy an intrusion prevention signature that blocks the known exploit traffic as a compensating control

B. Mark the finding as a false positive so that it no longer appears in scan reports

C. Lower the CVSS environmental score in the scanner so that the finding falls below the remediation threshold

D. Move the server into an isolated network segment with firewall rules that permit only the required hosts and ports

E. Rescan the server immediately so that the ticket can be closed

Question 23 [Matching]

Match each backup type with its description.

Items	Descriptions
1. Full	**A.** Saves only changes since the last full backup
2. Differential	**B.** Saves changes since the last backup of any type
3. Incremental	**C.** Captures system state at a specific point in time
4. Snapshot	**D.** Saves all selected data every time

Question 24 [Multiple Choice]

Fill in the blank: In the hot/warm/cold classification of disaster recovery sites, a _____ site is fully operational and can take over immediately.

A. Cold

B. Warm

C. Mirror

D. Hot

Question 25 [Multiple Choice]

Based specifically on the legal requirements governing its handling and storage, how should patient health information covered by HIPAA be categorized?

A. Secure data

B. Regulated data

C. Restricted data

D. Private data

Question 26 [Multiple Choice]

Which firewall allows for the most advanced traffic filtering?

A. Layer 6 firewall

B. Layer 5 firewall

C. Layer 4 firewall

D. Layer 7 firewall

Question 27 [Multiple Choice]

Maya must protect a public-facing web application from attacks such as SQL injection and cross-site scripting by inspecting incoming HTTP requests. Which firewall type should she deploy?

A. Next-generation firewall (NGFW)
B. Layer 4 firewall
C. Unified threat management (UTM)
D. Web application firewall (WAF)

Question 28 [Multiple Choice]

What is the role of an Acceptable Use Policy (AUP)?

A. Enforce multifactor authentication
B. Define technical audit procedures
C. Identify disaster recovery contacts
D. Outline appropriate use of organizational assets

Question 29 [Multiple Choice]

What is the purpose of a security baseline in an organization?

A. To block zero-day threats
B. To enforce encryption for backups
C. To define minimum configuration standards
D. To prioritize patching

Question 30 [Multiple Choice]

Finn's team leader has just texted him that an employee, who violated company policy by bringing in a file on a USB flash drive, has just reported that their computer is infected with locking ransomware. Why would Finn consider this a serious situation?

A. It sets a precedent by encouraging other employees to violate company policy.
B. It can encrypt all files on any network that is connected to the employee's computer.
C. The organization may be forced to pay up to $500 for the ransom.
D. The employee would have to wait at least an hour before their computer could be restored.

Question 31 [Multiple Choice]

Which type of log is specifically maintained as an accountability trail of security-relevant events, such as logins, permission changes, and file access?

A. Access list
B. Error log
C. System log
D. Audit log

Question 32 [Matching]

Match each social engineering technique to its description.

Items	Descriptions
1. Shoulder surfing	**A.** Pretending to be someone with authority
2. Vishing	**B.** Text message with malicious link
3. Impersonation	**C.** Watching a user enter credentials
4. Smishing	**D.** Voice-based phishing

Question 33 [Multiple Choice]

Which principle is followed when users are granted only the minimum system permissions required to perform their assigned job duties?

A. Role rotation
B. Need-to-know
C. Defense in depth
D. Least privilege

Question 34 [Multiple Choice]

Muchaneta is investigating a security incident in which the smartphone of the CEO was compromised and confidential data was stolen. She suspects that it was an attack that used Bluetooth. Which attack would this be?

A. Blueswiping
B. Bluesnarfing
C. Bluejacking
D. Bluehiking

Question 35 [Multiple Choice]

A systems administrator needs to ensure that only authorized personnel can access the datacenter. Which control type should be implemented?

A. Physical
B. Administrative
C. Corrective
D. Technical

Question 36 [Multiple Choice]

Yua has discovered that the network switch is broadcasting all packets to all devices. She suspects it is the result of an attack that has overflowed the switch MAC address table. Which type of attack would she report?

A. MAC spoofing attack
B. MAC cloning attack
C. ARP poisoning attack
D. MAC flooding attack

Question 37 [Multiple Choice]

What is the difference between a vulnerability scan and a penetration test?

A. A scan is passive; a test actively exploits vulnerabilities
B. A scan needs credentials, while a test is run without them
C. A test completes faster than an automated scan
D. A scan remediates the issues it finds; a test only identifies them

Question 38 [Multiple Choice]

Which of the following is NOT true about microservices?

A. Microservices are commonly used in cloud-native application architectures
B. Microservice boundaries are typically aligned with business capabilities rather than technical layers
C. Microservices are used only when an application is developed locally and then imported into the cloud
D. Microservice architecture addresses drawbacks of monolithic design by dividing an application into smaller, independently deployable services

Question 39 [Multiple Choice]

Which Windows capability can centrally enforce security settings on domain-joined workstations?

A. NetFlow
B. SELinux
C. RADIUS
D. Group Policy

Question 40 [Multiple Choice]

Mary Alice is developing procedures for restoring IT systems and operations after a disaster causes a major outage. What type of planning is this?

A. Business impact analysis planning
B. Risk IT planning
C. IT contingency planning
D. Disaster recovery planning

Question 41 [Multiple Choice]

An organization enforces strong password complexity but cannot implement MFA for a legacy application. Which of the following would BEST compensate for the missing MFA?

A. Strong password complexity
B. Geolocation restrictions
C. Daily password rotation
D. Security awareness training

Question 42 [Multiple Choice]

Which system is responsible for translating domain names into IP addresses?

A. ARP
B. DHCP
C. DNS
D. NAT

Question 43 [Matching]

Match each wireless protocol to its description.

Items	Descriptions
1. WPA2	**A.** Unsecured, no authentication
2. WEP	**B.** Outdated and vulnerable encryption
3. WPA3	**C.** Strongest current standard with forward secrecy
4. Open	**D.** Uses AES with PSK

Question 44 [Multiple Choice]

A SIEM shows a user's account authenticating from New York and, four minutes later, from Singapore, with active sessions in both places and no VPN in use. Which indicator of malicious activity does this pattern represent?

A. Resource consumption
B. Impossible travel
C. Missing logs
D. Blocked content

Question 45 [Ordering]

A compromised database server is still powered on when the forensic analyst arrives. Several sources of evidence must be collected before the machine is shut down and its disk is imaged. Arrange the evidence sources in the sequence the order of volatility requires.

Place the following in the correct order:

A. Archived backup tapes held in an offsite vault
B. Files stored on the server's hard drive
C. Contents of the CPU cache and registers
D. Data held in RAM, including the malware process running in memory
E. Temporary files in the system's spool and cache directories
F. The ARP cache and the list of active network connections

Question 46 [Multiple Choice]

What is the goal of using geofencing in security policy enforcement?

A. Speed up DNS resolution for remote users
B. Reduce malware downloads from risky external sites
C. Block logins from unapproved geographic areas
D. Detect insider threats through behavior analytics

Question 47 [Multiple Choice]

Scenario: An organization receives a legal order to preserve all email records for a lawsuit. What process does this trigger?

A. Data loss prevention
B. File hashing
C. Chain of custody
D. Litigation hold

Question 48 [Multiple Choice]

Which event most directly confirms that a web filter successfully enforced a configured block rule?

A. Blocked content
B. Account lockout
C. Resource manipulation
D. Out-of-cycle logging

Question 49 [Multiple Choice]

What is the purpose of sandboxing suspicious files in a secure lab environment?

A. Upload samples to the SIEM
B. Obfuscate file metadata
C. Encrypt the file for secure analysis
D. Execute code without impacting production

Question 50 [Multiple Choice]

Which social engineering attack is masquerading as a real or fictitious character and then playing out the role of that person on a target?

A. Impersonation
B. Pretexting
C. Pretending
D. Acting

Question 51 [Multiple Choice]

What forensic process ensures data has not been modified during collection or transfer?

A. Backup
B. Whitelisting
C. Encryption
D. Hashing

Question 52 [Multiple Choice]

Which of the following attacks is based on the principle that when a user is currently authenticated on a website and then loads another webpage, the new page inherits the identity and privileges of the first website?

A. DRCR
B. CSRF
C. DLLS
D. SSFR

Question 53 [Multiple Choice]

Arkady has been asked to explain to a manager why the SOC is not performing vulnerability scans continuously over all systems. Which of the following would NOT be a reason Arkady would give?

A. Expense
B. Workflow interruptions
C. Low risk tolerance
D. Technical constraints

Question 54 [Multiple Choice]

What is the role of a playbook in a SOAR platform?

A. Track audit trail for password resets
B. Schedule identity rotations
C. Store backup encryption keys
D. Execute scripted, automated incident responses

Question 55 [Multiple Choice]

Which type of attacker is typically motivated by political or social causes?

A. Script kiddie
B. Hacktivist
C. Nation-state
D. Insider

Question 56 [Multiple Choice]

Which risk treatment involves accepting a known risk due to its low likelihood and impact?

A. Transfer
B. Mitigate
C. Accept
D. Avoid

Question 57 [Multiple Choice]

Himari needs to protect against potential attacks on DNS. What are the locations she would need to protect?

A. Local host file and external DNS server
B. Web server buffer and host DNS server
C. Reply referrer and domain buffer
D. Web browser and browser add-on

Question 58 [Multiple Choice]

Gjord has been assigned to design an implementation of IPSec at an old manufacturing plant that has legacy network equipment and many devices. Which implementation will he choose?

A. Hardware security module (HSM)
B. Bump-in-the-Wire (BITW)
C. Native integration in each device's operating system
D. Bump-in-the-Stack (BITS)

Question 59 [Multiple Choice]

A firm publishes an acceptable use policy that tells employees exactly how they must handle customer data and requires an annual signed acknowledgment. Which control type is designed to direct or mandate specific behavior in this way?

A. Corrective
B. Detective
C. Directive
D. Preventive

Question 60 [Multiple Choice]

Which of the following performs a real-time lookup of a certificate's status?

A. Pinning
B. OCSP
C. Clipping
D. Remote lookup protocol (RLP)

Question 61 [Multiple Choice]

A contract is approved by email, and the sender later denies having sent the approval. The security team wants a mechanism that cryptographically proves the message originated from that sender so the claim cannot be credibly denied. Which concept provides this?

A. Authentication
B. Non-repudiation
C. Availability
D. Confidentiality

Question 62 [Multiple Choice]

Which attack takes over an authenticated user's active session, typically by stealing or reusing the session token, to impersonate that user?

A. Man-in-the-middle
B. Buffer overflow
C. Session hijacking
D. Clickjacking

Question 63 [Select Two]
Select TWO common indicators of a phishing attack:

A. Suspicious links requesting urgent action
B. IP address conflicts
C. Email with spoofed domain
D. Frequent system reboots
E. Embedded command-line syntax in file name

Question 64 [Multiple Choice]
Alarik is explaining to a colleague about digital certificates. Which of the following statements would he use to correctly describe the need for digital certificates?

A. It can speed up processing time when using a web browser.
B. It can hide the public key so that it cannot be abused.
C. It can confirm the true identity of the sender of an encrypted message.
D. It can replace digital signatures with a more robust technology.

Question 65 [Multiple Choice]
Which of the following is a key advantage of using immutable backups?

A. Faster recovery time
B. Supports differential compression
C. Cannot be altered by ransomware
D. Stored in cold storage

Question 66 [Multiple Choice]
A security team proactively searches logs, endpoint telemetry, and network data for evidence of threats that automated alerts have not identified. Which activity is the team performing?

A. Threat hunting
B. Log archiving
C. Vulnerability scanning
D. User provisioning

Question 67 [Multiple Choice]
Fill in the blank: In risk management, the _____ is the amount of loss expected from a single event.

A. Governance framework
B. Business impact analysis
C. Security awareness training
D. SLE (Single Loss Expectancy)

Question 68 [Multiple Choice]
Giovanni is completing a report on risks. To which risk option would he classify the action that the organization has decided not to construct a new data center because it would be located in an earthquake zone?

A. Reject
B. Prevent
C. Avoid
D. Transfer

Question 69 [Multiple Choice]

Which asset-management activity assigns accountability for a hardware, software, or data asset to a responsible party?

A. Inventory
B. Classification
C. Sanitization
D. Ownership

Question 70 [Matching]

Match each security tool to its function.

Items	Descriptions
1. EDR	**A.** Monitors endpoint activity and contains threats
2. SOAR	**B.** Blocks or permits network traffic
3. SIEM	**C.** Real-time correlation of security events
4. Firewall	**D.** Automates incident response playbooks

Question 71 [Multiple Choice]

Which of the following BEST describes a watering hole attack?

A. Manipulating trusted websites to infect a targeted group
B. Sending malware through watering hole-themed spam
C. Poisoning a data lake to spread malware
D. Infecting a local DNS cache

Question 72 [Multiple Choice]

What is a key benefit of using multifactor authentication (MFA)?

A. Prevents phishing
B. Speeds up authentication
C. Reduces reliance on passwords alone
D. Prevents all account lockouts

Question 73 [Multiple Choice]

A financial services company has integrated its vulnerability scanner, configuration monitoring, and SIEM so that risk register entries are updated automatically whenever a control fails, a new asset appears, or an exposure changes. Which type of risk assessment does this approach represent?

A. Ad hoc
B. Recurring
C. One-time
D. Continuous

Question 74 [Multiple Choice]

Fill in the blank: A _____ attack attempts to exploit a lack of input validation to manipulate backend database queries.

A. Buffer overflow
B. SQL injection
C. Command injection
D. Cross-site scripting

Question 75 [Multiple Choice]

Nala needs to purchase WLCs for the office. What type of AP must she also purchase that can be managed by a WLC?

A. Controller-based (lightweight) AP
B. Stand-alone (autonomous) AP
C. Any type of AP can be managed by a WLC.
D. Wireless range extender

Question 76 [Multiple Choice]

Unlike open-source intelligence (OSINT) feeds, where do proprietary third-party threat intelligence providers primarily obtain the telemetry that powers their commercial feeds?

A. From free and public sources such as vendor blogs and advisories
B. From government contractors working under classified agreements
C. From paid informants recruited inside criminal forums
D. From the information they collect from their own customers

Question 77 [Multiple Choice]

What is the purpose of implementing least functionality on critical systems?

A. To reduce the system's attack surface
B. To increase DNS query speed
C. To simplify user access
D. To conserve power usage

Question 78 [Multiple Choice]

Scenario: A user complains their account was locked out overnight, though they were not logged in. What should be investigated first?

A. File integrity hashes
B. Group policy configurations
C. Time server synchronization
D. Authentication logs

Question 79 [Multiple Choice]

After a breach, investigators need a record showing which files each user opened and which commands they ran, along with timestamps. Which component of the AAA framework produces this record?

A. Authentication
B. Authorization
C. Attestation
D. Accounting

Question 80 [Multiple Choice]

Jan's organization uses a four-level data classification scheme: Public, Internal, Confidential, and Critical, in order of increasing impact. Data has been identified that, if compromised, would severely impact the enterprise's function and mission. Which classification should Jan assign?

A. Public
B. Confidential
C. Internal
D. Critical

Question 81 [Matching]

Match each logging concept to its function.

Items	Descriptions
1. Chain of custody	**A.** Tracks evidence handling
2. Syslog	**B.** Standard protocol for log forwarding
3. Log aggregation	**C.** Stores logs for compliance timeframes
4. Log retention	**D.** Centralized storage of security events

Question 82 [Multiple Choice]

Hannah is planning incident response testing exercises for the next year. This exercise will be a monthly 30-minute discussion of a scenario conducted in an informal and stress-free environment. What is the name of this exercise?

A. Tabletop
B. Simulation
C. Walkthrough
D. Relaxed scenario event (RSE)

Question 83 [Multiple Choice]

Fill in the blank: The principle of _____ ensures that changes to systems are approved, documented, and tested.

A. Configuration management
B. Risk management
C. Change management
D. Incident management

Question 84 [Matching]

A privacy officer is documenting who is responsible for a customer database. Match each role to the description of its responsibility.

Items	Descriptions
1. Data owner	**A.** Technical role that implements backups, permissions, and encryption on behalf of the accountable manager
2. Data controller	**B.** Entity that determines the purposes and means of processing personal data
3. Data processor	**C.** Independent party that tests controls and issues an opinion on whether they operate effectively
4. Data custodian	**D.** Executive who leads the overall security program and reports to the board
5. Data subject	**E.** Identifiable individual whom the personal data is about
	F. Third party that handles personal data only on the documented instructions of another organization
	G. Senior manager accountable for a data set who decides its classification and who may access it

Question 85 [Matching]

Match each detection method to its characteristic.

Items	Descriptions
1. Heuristic	**A.** Evaluates how a process acts over time
2. Signature-based	**B.** Flags deviations from established baselines
3. Anomaly-based	**C.** Identifies threats using generic rule sets
4. Behavior-based	**D.** Uses patterns of known malware

Question 86 [Multiple Choice]

A deliberate attack on electrical infrastructure causes a power blackout at an organization's facility. Which type of physical attack does this scenario illustrate?

- **A.** Brute force
- **B.** Environmental
- **C.** Distributed denial-of-service (DDoS)
- **D.** RFID cloning

Question 87 [Multiple Choice]

Scenario: A company decides not to patch a vulnerability in an internal test environment because it has no external exposure. What risk response strategy is this?

- **A.** Transfer
- **B.** Acceptance
- **C.** Avoidance
- **D.** Mitigation

Question 88 [Multiple Choice]

A security analyst disables SMBv1 across all servers. What type of control is this?

- **A.** Physical
- **B.** Preventive
- **C.** Detective
- **D.** Compensating

Question 89 [Multiple Choice]

Which type of monitoring methodology looks for statistical deviations from a baseline?

- **A.** Anomaly-based monitoring
- **B.** Rule-based monitoring
- **C.** Signature-based monitoring
- **D.** Heuristic monitoring

Question 90 [Multiple Choice]

Which artifact is MOST useful for preserving a suspect system’s disk evidence for repeatable offline forensic analysis?

- **A.** Log rotation schedule
- **B.** Real-time network analytics
- **C.** Automated patch deployment
- **D.** Immutable system image

Answer Key

Each answer is followed by the reasoning behind it, including why the other options fall short.

Q1: A

A. Fail-closed is correct. In fail-closed mode a failed appliance blocks all traffic passing through it, prioritizing security over availability, which is exactly the stated requirement. C. Fail-open is incorrect. Fail-open lets traffic continue to flow when the device fails, preserving availability but leaving traffic uninspected — the opposite of the requirement. D. Passive operation is incorrect. Active versus passive describes whether a device can act on traffic during normal operation; it is not a failure mode. B. Tap/monitor mode is incorrect. A device on a tap or monitor port only receives a copy of traffic for analysis; it never sits in the traffic path, so it cannot block anything, failed or not.

Q2: A

D. SLA is incorrect because a service-level agreement defines measurable performance commitments between a provider and a customer, not rules for user behavior on systems. C. NDA is incorrect because a non-disclosure agreement protects confidential information exchanged between parties; it does not define permitted system actions. B. MOU is incorrect because a memorandum of understanding documents an informal agreement between organizations, not what users may do on the network. A. AUP is correct: an acceptable use policy defines the actions users may and may not perform while accessing an organization's systems and networking equipment.

Q3: 1 = A; 2 = C; 3 = D; 4 = B

The correct mapping is: Service account is used by applications or scripts — it is a non-human account created so that software processes can authenticate and access resources without human intervention. Privileged user has elevated permissions and higher risk — admins and root users can make system-wide changes, making their accounts high-value targets requiring extra controls like PAM and MFA. Standard user has basic access for daily tasks — limited to the resources needed for their role under least privilege. Guest account has limited, temporary access — typically restricted to minimal resources and revoked after a short period, often used for contractor or visitor access.

Q4: C

B. Password policy is incorrect. A password policy is a preventive control — it reduces the likelihood of unauthorized access before it occurs, not after a breach has happened. D. Firewall is incorrect. A firewall is primarily preventive; it blocks unauthorized traffic at network boundaries but does not identify breaches that have already occurred inside the perimeter. C. IDS is correct. An Intrusion Detection System monitors network traffic or host activity for indicators of malicious behavior and generates alerts — it is the textbook detective control. Unlike an IPS (which actively blocks), an IDS only detects and reports after suspicious activity occurs or is in progress. A. MFA is incorrect. Multi-factor authentication is a preventive control that blocks unauthorized access attempts — it operates before a breach, not after.

Q5: A

B. Firewall is incorrect. A firewall filters traffic based on network rules (IP, port, protocol) — it cannot detect behavioral anomalies tied to specific internal users or track gradual data exfiltration patterns over time. D. SIEM is incorrect. A SIEM aggregates and correlates logs and can detect some anomalies, but it lacks the per-user behavioral baselining that makes UEBA specifically effective for insider threat detection. A. UEBA is correct. UEBA (User and Entity Behavior Analytics) establishes behavioral baselines for individual users, then detects deviations — such as an employee accessing unusually large volumes of files at odd hours or transferring data to external storage. This pattern-over-time analysis makes it the most effective tool for detecting slow, covert insider exfiltration. C. Load balancer is incorrect. A load balancer distributes traffic for performance and availability — it provides no security monitoring capability.

Q6: D

A. Limit user permissions is incorrect. Limiting user permissions is the goal of least privilege, an access control principle — not the primary objective of business continuity planning. C. Protect physical buildings is incorrect. Physical facility protection is a physical security concern. BCP is concerned with operational continuity of business functions, not building security. D. Maintain operations during a disruption is correct. A BCP defines strategies and procedures to ensure critical business functions continue during and after a disruptive event — whether a natural disaster, cyberattack, or major system failure. It includes alternate site strategies, communication plans, and recovery priorities tied to RTO and RPO values. B. Monitor encrypted traffic is incorrect. Encrypted traffic monitoring (SSL/TLS inspection) is a security operations function, unrelated to continuity planning.

Q7: C

A. Being installed by default on many Windows systems is a genuine reason threat actors use PowerShell, so it is not the correct choice. B. Executing commands in memory, which reduces the payload files written to disk, is a genuine reason, so it is not the correct choice. C. Correct — PowerShell cannot execute before an operating system environment has loaded; it requires a running Windows environment, so this is NOT a reason threat actors use it. D. Being a legitimate administrative tool that security controls may trust or allow is a genuine reason, so it is not the correct choice.

Q8: C

C is correct (Loss of license): the regulator withdrew the bank's authorization to conduct business, which is the loss of a license, the most severe regulatory consequence because it ends the organization's ability to operate legally in that jurisdiction. D is incorrect (Fines) because fines are monetary penalties that punish non-compliance while allowing the organization to keep operating. A is incorrect (Sanctions) because sanctions are restrictions or penalties imposed on an organization, such as limits on activities or increased oversight, that fall short of revoking its right to operate. B is incorrect (Contractual impacts) because contractual impacts arise from private agreements with customers or partners, such as penalties, termination clauses, or lost deals, not from a regulator's action.

Q9: B

D. RPO (Recovery Point Objective) is incorrect. RPO defines the maximum acceptable amount of data loss, expressed as the point in time back to which data must be recoverable; it addresses data loss, not outage duration. B. RTO (Recovery Time Objective) is correct. RTO defines the maximum tolerable length of time a system can be down before it must be restored, so it directly expresses how long an organization can tolerate an outage. C. MTBF (Mean Time Between Failures) is incorrect. MTBF is a reliability metric describing the average operating time between failures of a component; it does not set a tolerance for outage length. A. MTTR (Mean Time To Repair) is incorrect. MTTR is the average time actually taken to repair a failed component, a measured average rather than the outage tolerance the organization sets in advance.

Q10: B > A > C > F > D > E

Correct order: 1. Isolate the infected laptop from the network — the compromise is already confirmed, so containment comes first and stops the beaconing. 2. Capture a memory image and preserve logs before cleaning — volatile evidence must be collected while it still exists, because eradication destroys it. 3. Eradicate the malware and remove its persistence mechanisms — remove the keylogger and any footholds it created. 4. Patch the exploited weakness and harden the configuration — close the hole so the same attack cannot recur. 5. Restore the system from a known-good backup — return clean data and services to the user. 6. Monitor the device to confirm the threat does not return — watch for renewed beaconing before closing the case.

Q11: A

D. IoT devices may react differently to test traffic is incorrect — this is a genuine disadvantage; IoT devices often run minimal or proprietary firmware that can crash or behave unpredictably when probed. C. Sending test traffic increases the risk of the endpoints malfunctioning is incorrect — this is a valid disadvantage; incompatible queries can trigger buffer overflows or denial-of-service conditions on sensitive devices. B. Smaller networks can become overloaded with high volumes of test traffic is incorrect — this is a real drawback; aggressive scanning saturates low-bandwidth links and disrupts normal operations. A. Active scanning can accelerate the collection of data is correct. Faster data collection is actually an advantage of active scanning, not a disadvantage — Bohdan would cite it as a benefit, not a reason to avoid active scans.

Q12: A

A is correct (The right to be forgotten): under regulations such as the GDPR, a data subject may request erasure of personal data, and the controller must delete it unless a legal basis for retention exists. The retailer checked for retention obligations and then scheduled deletion, which is exactly the right-to-erasure workflow. B is incorrect (data portability) because portability entitles the subject to receive their data in a machine-readable format or move it to another provider, not to have it erased. D is incorrect (ownership) because ownership defines which party is accountable for a data set; it is an organizational role, not a right a customer exercises. C is incorrect (data inventory) because a data inventory is an internal record of what data the organization holds and where; it is a compliance obligation, not a right granted to individuals.

Q13: D

C. Vishing is incorrect because it is conducted through voice calls, not email. D. Phishing is correct: a fraudulent email that impersonates a legitimate organization and directs the recipient to a fake login page is a classic phishing attack. B. Smishing is incorrect because its delivery vector is SMS text messaging; here the message arrived by email. A. Whaling is incorrect because it targets high-profile executives specifically, and nothing indicates the recipient holds such a role.

Q14: C

B. SIEM automates response actions; SOAR only collects logs is incorrect. This reverses the actual functions of both platforms. A. SOAR collects logs; SIEM performs orchestration is incorrect. Again, both roles are swapped from their actual definitions. C. SIEM aggregates and correlates logs; SOAR automates workflows is correct. SIEM (Security Information and Event Management) ingests and correlates logs from across the environment to detect threats. SOAR (Security Orchestration, Automation, and Response) then automates the playbook-driven response to those detections, reducing manual analyst workload. D. Both perform the same function is incorrect. While they are often deployed together, they serve distinct and complementary purposes.

Q15: A

D. 'Zero trust assumes that networks have already been infiltrated by threat actors' is a true statement about zero trust, so it is not the answer. A. 'Zero trust is designed to make a system trusted' is correct as the NOT-true statement. Zero trust does the opposite: it grants no automatic trust and continuously verifies every entity, whether inside or outside the network. C. 'The motto of zero trust is Never trust, always verify' is a true statement, so it is not the answer. B. 'Zero trust acknowledges that implicit trust is a vulnerability' is a true statement, since removing implicit trust is central to the model, so it is not the answer.

Q16: 1 = A; 2 = B; 3 = D; 4 = C

The correct mapping is: Acceptable Use Policy (AUP) outlines responsible use of IT resources — defining what employees are and are not permitted to do with organizational technology. BYOD Policy limits and governs personal device usage — setting security requirements (e.g., MDM enrollment, screen lock) for employee-owned devices accessing company data. Clean Desk Policy ensures sensitive information is not left visible or accessible when workstations are unattended, reducing physical exposure of confidential data. Data Retention Policy defines how long data is kept before it must be archived or destroyed, balancing legal compliance with storage efficiency.

Q17: D > C > E > B > A

Correct order: 1. Identify the audience groups and the threats the program must address — development begins with understanding who needs training and which risks, such as invoice fraud for finance or whaling for executives, matter most. 2. Develop role-based training content and phishing simulation templates — with the needs defined, the material and simulations are built to match each audience. 3. Deliver the training modules and launch the first phishing simulation campaign — execution puts the program in front of employees and produces the first behavioral data. 4. Compile the initial report of phishing click rates and training completion percentages — initial reporting establishes the baseline against which improvement will be measured and is shared with leadership. 5. Track recurring metrics each quarter and update the content as threats change — recurring reporting and monitoring turn a one-time campaign into a program that adapts over time. Reporting before delivery would have no data to report, and building content before knowing the audience would produce generic training that misses the roles most at risk.

Q18: A

D. Encryption is incorrect because it protects data confidentiality and does not restrict an attacker's movement between network zones. A. Segmentation is correct: dividing the network into separately controlled zones restricts lateral movement, so compromising one system does not grant reach into other zones. B. Patching is incorrect because it remediates known software flaws; it does not contain movement between zones after a compromise. C. Decommissioning is incorrect because it securely removes systems from service and does not constrain an active attacker's movement across the network.

Q19: A

A is correct (Operational): operational controls are the day-to-day security tasks carried out by people, such as analysts reviewing logs and manually executing an incident-response procedure. B is incorrect (Technical): technical controls are enforced by technology like firewalls, encryption, or an IDS, not by human-run routines. C is incorrect (Physical): physical controls protect the tangible environment with fences, locks, or cameras. D is incorrect (Managerial): managerial controls are the policies, risk assessments, and oversight that direct the program rather than the hands-on execution of it.

Q20: A

C. Antivirus signature is incorrect. Signature-based AV is a preventive/detective technical control; it stops malware but does not visibly dissuade attackers. A. Access badge with security camera is correct. Visible cameras and badge readers are classic deterrent controls because their mere presence discourages would-be intruders from attempting unauthorized entry, even before any detection or prevention occurs. B. Data classification policy is incorrect. Classification policies are administrative/directive controls that guide how data is labeled and handled; they do not deter attackers in a visible way. D. Disk encryption is incorrect. Disk encryption is a preventive technical control protecting data confidentiality; it is invisible to an attacker and therefore does not deter.

Q21: A

C. PCI DSS is incorrect. The Payment Card Industry Data Security Standard governs the protection of cardholder data, not corporate financial reporting. D. HIPAA is incorrect. HIPAA protects the privacy and security of health information, not financial reporting. B. GDPR is incorrect. The General Data Protection Regulation governs personal data of EU residents, not financial reporting integrity. A. SOX is correct. The Sarbanes-Oxley Act mandates controls and accountability over corporate financial reporting to ensure its accuracy and integrity for publicly traded companies.

Q22: A, D

D and A are correct: when patching is impossible, vulnerability response falls back on segmentation and compensating controls. Isolating the server limits which systems can reach the vulnerable service, and an IPS signature that blocks the exploit pattern reduces the likelihood of a successful attack until the patch arrives. B is incorrect (mark the finding as a false positive) because the finding is real; hiding it removes visibility without changing the exposure. C is incorrect (lower the CVSS environmental score) because environmental scores must reflect mitigations actually in place; editing the number to escape a threshold is misrepresentation, not risk reduction. E is incorrect (rescan immediately to close the ticket) because rescanning validates remediation already performed; nothing has changed, so it would confirm the flaw is still present.

Q23: 1 = D; 2 = A; 3 = B; 4 = C

Full matches "Saves all selected data every time" because a full backup copies every in-scope file regardless of change state, simplifying restore at the cost of storage. Differential matches "Saves only changes since the last full backup," growing each day until the next full and allowing restore with just the full plus the latest differential. Incremental matches "Saves changes since the last backup of any type," producing the smallest daily backups but requiring the full plus every incremental in order to restore. Snapshot matches "Captures system state at a specific point in time," typically using storage- or hypervisor-level metadata to enable near-instant rollback.

Q24: D

B. Warm is incorrect: a warm site has infrastructure and some systems in place but requires setup time and data restoration before it can take over. A. Cold is incorrect: a cold site provides only basic space and utilities, requiring the longest time to become operational. D. Hot is correct: in the hot/warm/cold classification, a hot site is fully operational with systems and current data ready, so it can take over immediately — lowest RTO, highest cost. C. Mirror is incorrect: it is not one of the hot/warm/cold site classifications used to categorize disaster recovery sites.

Q25: B

C. Restricted data is incorrect because 'restricted' is an access-based classification level an organization may assign; it does not describe the category defined by legal protection requirements. B. Regulated data is correct: patient health information under HIPAA is governed by specific legal requirements for its handling and storage, which is precisely what defines regulated data. A. Secure data is incorrect because 'secure' describes a protection state, not a recognized data category. D. Private data is incorrect because, while patient information is private in the general sense, the category determined by legal handling requirements such as HIPAA is regulated data.

Q26: D

C. Layer 4 firewall is incorrect. A Layer 4 firewall filters on transport-layer information such as IP addresses, ports, and protocols, so it cannot inspect application content. B. Layer 5 firewall is incorrect. Filtering at the session layer still cannot examine application-layer payloads, so it does not offer the most advanced filtering. A. Layer 6 firewall is incorrect. Even at the presentation layer, a firewall does not perform full application-aware inspection of protocols and content. D. Layer 7 firewall is correct. A Layer 7 (application-layer) firewall inspects and filters traffic based on application-specific protocols and content, providing the most advanced traffic filtering of the options.

Q27: D

D. Web application firewall (WAF) is correct. A WAF inspects HTTP/HTTPS requests at the application layer and blocks web-specific attacks such as SQL injection and cross-site scripting before they reach the application. C. Unified threat management (UTM) is incorrect. A UTM bundles several general-purpose security functions such as firewall, antivirus, and content filtering; it is not specialized in parsing HTTP requests to protect a specific web application. A. Next-generation firewall (NGFW) is incorrect. An NGFW adds application awareness and intrusion prevention to network firewalling, but it is not purpose-built to inspect web requests for attacks like SQL injection the way a WAF is. B. Layer 4 firewall is incorrect. A Layer 4 firewall filters on transport-layer information such as IP addresses, ports, and protocols, so it cannot examine the content of HTTP requests at all.

Q28: D

B. Define technical audit procedures is incorrect. Audit procedures are defined in audit or compliance standards, not in an AUP, which addresses user conduct. D. Outline appropriate use of organizational assets is correct. An Acceptable Use Policy defines what constitutes permitted and prohibited use of company systems, networks, and data by users, setting expectations and the basis for enforcement. A. Enforce multifactor authentication is incorrect. MFA is a technical control implemented through configuration and standards; an AUP is a governance document, not an enforcement mechanism. C. Identify disaster recovery contacts is incorrect. DR contacts and roles belong in a disaster recovery or business continuity plan, not in the AUP.

Q29: C

C (To define minimum configuration standards) is correct: a security baseline states the minimum settings every system of a given type must meet, covering patch level, disabled services, account policy and auditing, and gives the reference point against which configuration drift is measured. A (To block zero-day threats) is incorrect because no configuration standard stops an unknown exploit; that requires behavioural detection and layered defences. D (To prioritize patching) is incorrect because ranking patches by risk is vulnerability management, which uses the baseline as input rather than being its purpose. B (To enforce encryption for backups) is incorrect because that is one specific control a baseline might contain, not what a baseline is.

Q30: B

A. Setting a precedent for policy violations is an HR and disciplinary concern, not the technical security threat that makes this situation serious. B. Correct — the malware introduced from the USB drive can spread from the infected computer to network shares and other connected devices it can reach, encrypting their files and turning a single infection into an organization-wide data-loss event. C. A fixed $500 ransom figure is arbitrary and understates the problem; the seriousness comes from potential loss of data across the network, not the amount demanded. D. A one-hour recovery delay trivializes the impact; the real danger is widespread, possibly unrecoverable, encryption of organizational data rather than a short wait.

Q31: D

C. System log is incorrect. System logs capture operating system events like service starts, hardware messages, and kernel warnings, not specifically the security/audit trail. D. Audit log is correct. An audit log records security-relevant events (logins, permission changes, file access) specifically for accountability, compliance review, and forensic analysis. B. Error log is incorrect. Error logs capture faults and exceptions within applications or services; they focus on troubleshooting rather than security accountability. A. Access list is incorrect. An access control list is a policy construct that defines who may access what; it is a configuration object, not a record of events.

Q32: 1 = C; 2 = D; 3 = A; 4 = B

The correct mapping is: Shoulder surfing involves physically watching a user enter credentials — the attacker is literally looking over the target's shoulder. Vishing is voice-based phishing, where attackers call victims pretending to be IT support or banks. Impersonation means pretending to be someone with authority (e.g., an executive or IT admin) to manipulate a target — broader than a phone call alone. Smishing uses SMS text messages containing malicious links or urgent requests. Each technique exploits different communication channels and psychological triggers rather than technical vulnerabilities.

Q33: D

B. Need-to-know is incorrect because it governs access to specific information based on necessity, whereas this scenario concerns the level of system permissions granted to users. D. Least privilege is correct because it grants users only the minimum permissions required to perform their assigned duties, reducing the attack surface and limiting the damage a compromised account can cause. C. Defense in depth is incorrect because it describes layering multiple overlapping security controls, not sizing user permissions. A. Role rotation is incorrect because rotating job responsibilities helps detect fraud and reduce dependency on a single person; it does not define how permissions are granted.

Q34: B

A. Blueswiping is incorrect. This is not a recognized Bluetooth attack term. D. Bluehiking is incorrect. This is also not a recognized Bluetooth attack technique. C. Bluejacking is incorrect. Bluejacking involves sending unsolicited messages (such as contact cards) to nearby Bluetooth devices — it is an annoyance but does not steal data. B. Bluesnarfing is correct. Bluesnarfing is the unauthorized access to data stored on a Bluetooth-enabled device, such as contacts, emails, calendar entries, and files. Unlike bluejacking, bluesnarfing actively steals information, making it the attack described in the scenario where the CEO's confidential data was exfiltrated.

Q35: A

B. Administrative is incorrect. Administrative controls are policies and procedures; a policy alone does not physically stop unauthorized people from entering the datacenter. A. Physical is correct. Restricting who can physically enter the datacenter is achieved with physical controls: locked doors, badge readers, access control vestibules, and guards that protect the tangible facility. D. Technical is incorrect. Technical controls secure systems and data through technology (encryption, ACLs, authentication software); they do not govern bodily entry to a room. C. Corrective is incorrect. Corrective controls act after an incident to restore normal operations; controlling entry is preventive, not corrective.

Q36: D

A. MAC spoofing attack is incorrect because spoofing forges a device's MAC address to impersonate another host; it does not fill the switch's MAC address table. B. MAC cloning attack is incorrect because cloning copies a legitimate device's MAC address, typically to bypass MAC filtering; it also does not overflow the table. D. MAC flooding attack is correct because sending frames with many bogus source MAC addresses exhausts the switch's MAC address table; the switch then fails open and broadcasts traffic out all ports like a hub, which matches the behavior Yua observed. C. ARP poisoning attack is incorrect because it corrupts hosts' ARP caches to redirect traffic between endpoints; it does not cause a switch to broadcast all packets.

Q37: A

A (A scan is passive; a test actively exploits vulnerabilities) is correct: a vulnerability scan uses automated tools to enumerate known weaknesses such as missing patches, weak ciphers and misconfigurations without exploiting them, while a penetration test actively exploits and chains them to prove real impact. D (A scan remediates the issues it finds; a test only identifies them) is incorrect because it reverses both roles: a scan only reports its findings, and remediation is a separate activity carried out by system owners. B (A scan needs credentials, while a test is run without them) is incorrect because credentialed scanning is an option rather than a requirement, and penetration testers frequently work with supplied credentials in assumed-breach or grey-box engagements. C (A test completes faster than an automated scan) is incorrect because a pentest is manual, scoped work spanning days or weeks, far slower than an automated scan.

Q38: C

D. "Microservice architecture addresses drawbacks of monolithic design by dividing an application into smaller, independently deployable services" is a true statement, so it is not the answer: decomposing a monolith into independently deployable services is the defining purpose of microservices. A. "Microservices are commonly used in cloud-native application architectures" is a true statement, so it is not the answer: cloud-native applications are typically composed of microservices, even though the two terms are not synonyms. C. "Microservices are used only when an application is developed locally and then imported into the cloud" is the correct answer (the NOT-true statement): microservices are an architectural approach that applies regardless of where the application is developed or deployed; they are not tied to a local-then-cloud workflow. B. "Microservice boundaries are typically aligned with business capabilities rather than technical layers" is a true statement, so it is not the answer: services are usually organized around business capabilities instead of technical tiers.

Q39: D

D. Group Policy is correct: in an Active Directory domain it pushes and enforces security configuration such as password rules, software restrictions, and audit settings across all domain-joined users and computers. B. SELinux is incorrect because it provides mandatory access control on Linux systems, not Windows workstations. A. NetFlow is incorrect because it exports network flow telemetry for traffic monitoring and configures nothing on endpoints. C. RADIUS is incorrect because it centralizes authentication, authorization, and accounting for network access rather than enforcing workstation settings.

Q40: D

A. Business impact analysis planning is incorrect: a BIA identifies critical functions and quantifies the impact of disruptions (for example RTO and RPO); it does not define restoration procedures. C. IT contingency planning is incorrect: it is a broad umbrella term, and the scenario specifically describes restoring IT systems and operations after a disaster, which the exam objectives call disaster recovery. D. Disaster recovery planning is correct: disaster recovery plans define the procedures for restoring IT systems and operations after a disaster causes a major outage. B. Risk IT planning is incorrect: it is not a recognized planning discipline in the SY0-701 objectives.

Q41: B

C. Daily password rotation is incorrect because forcing frequent changes encourages predictable password patterns and adds no independent check on who is logging in. D. Security awareness training is incorrect because it is an administrative measure that does not directly restrict access to the legacy application. A. Strong password complexity is incorrect because it is already enforced; an existing control cannot compensate for the missing one. B. Geolocation restrictions is correct because limiting logins to approved locations adds an independent condition on authentication, reducing the risk that stolen credentials alone grant access — a compensating control for the absent MFA.

Q42: C

B. DHCP is incorrect. The Dynamic Host Configuration Protocol assigns IP addresses and network configuration to hosts joining a network; it does not resolve names. C. DNS is correct. The Domain Name System translates human-readable domain names, such as example.com, into the IP addresses that computers use to route traffic, using a hierarchy of resolvers and authoritative servers. A. ARP is incorrect. The Address Resolution Protocol maps an IP address to a MAC address on the local network segment; it performs a different kind of resolution than name-to-IP. D. NAT is incorrect. Network Address Translation rewrites private IP addresses to public ones (and back) at a network boundary; it does not translate domain names.

Q43: 1 = D; 2 = B; 3 = C; 4 = A

The correct mapping is: WPA2 uses AES encryption with a pre-shared key (PSK), providing strong security and is still widely deployed in enterprise and home environments. WEP uses RC4-based encryption and is cryptographically broken — it can be cracked in minutes using freely available tools and should never be used. WPA3 is the strongest current standard, introducing SAE authentication and perfect forward secrecy — compromising one session's key does not expose past or future sessions. Open networks have no encryption or authentication, transmitting all traffic in plaintext and offering no protection against passive eavesdropping.

Q44: B

B is correct (Impossible travel): logins from two distant locations within a window too short to physically travel indicate a stolen credential being used concurrently. A is incorrect (Resource consumption): resource consumption refers to unusual spikes in CPU, memory, or bandwidth, not geographically impossible logins. D is incorrect (Blocked content): blocked content shows that a control stopped access to a resource, which is unrelated to login geography. C is incorrect (Missing logs): missing logs suggest an attacker deleted evidence, which is not what this timeline shows.

Q45: C > D > F > E > B > A

Correct order: 1. Contents of the CPU cache and registers — these are overwritten in fractions of a second by ordinary processing, so anything not captured immediately is gone. 2. Data held in RAM, including the malware process running in memory — memory holds injected code, plaintext credentials, and open sockets, and it disappears the moment the system loses power. 3. The ARP cache and the list of active network connections — connection state and cache entries age out within minutes even while the host stays up. 4. Temporary files in the system's spool and cache directories — these survive longer than memory but are routinely purged by the operating system or by cleanup jobs. 5. Files stored on the server's hard drive — disk data persists across a reboot, so it can be imaged after the live evidence has been secured. 6. Archived backup tapes held in an offsite vault — backups are the least volatile source of all and remain available long after the investigation begins. Collecting in this sequence maximizes evidentiary value and limits contamination of the more fragile sources.

Q46: C

D. Detect insider threats through behavior analytics is incorrect. Detecting malicious insiders relies on user-behavior analytics and monitoring, not on location-based access rules. C. Block logins from unapproved geographic areas is correct. Geofencing defines a virtual geographic boundary and enforces policy based on a device or user's location, so access attempts originating outside approved regions can be denied. A. Speed up DNS resolution for remote users is incorrect. DNS performance depends on resolvers and caching; geofencing does not affect name-resolution speed. B. Reduce malware downloads from risky external sites is incorrect. Blocking malicious downloads is the job of web filtering and endpoint protection, not of location-based access control.

Q47: D

A. Data loss prevention is incorrect. DLP monitors and blocks unauthorized transmission of sensitive data on an ongoing basis — it is a continuous security control, not a legal preservation directive triggered by a court order. D. Litigation hold is correct. A litigation hold (legal hold) is a formal directive issued when an organization anticipates or is involved in legal proceedings. It requires preservation of all potentially relevant electronically stored information (ESI) — emails, documents, chat logs — and overrides normal deletion or data retention schedules until the legal matter is resolved. C. Chain of custody is incorrect. Chain of custody documents who handled evidence and how — it is part of evidence management that follows after preservation, not the preservation directive itself. B. File hashing is incorrect. File hashing verifies data integrity by generating a cryptographic fingerprint — it confirms evidence has not been altered, but it does not initiate the legal hold process.

Q48: A

C. Resource manipulation is incorrect because tampering with system resources suggests malicious activity on a host, not a web filter applying policy. D. Out-of-cycle logging is incorrect because log entries appearing at unexpected times are an anomaly indicator unrelated to web filtering. B. Account lockout is incorrect because lockouts follow repeated failed authentication attempts, not URL or content enforcement. A. Blocked content is correct: when a web filter matches a request against a configured block rule, the direct observable outcome is that the requested content is denied and the event is logged.

Q49: D

C. Encrypt the file for secure analysis is incorrect. Sandboxing does not encrypt the sample; encryption protects confidentiality and is unrelated to safe execution. B. Obfuscate file metadata is incorrect. Obfuscating metadata hides information; it has nothing to do with the purpose of a sandbox. D. Execute code without impacting production is correct. A sandbox is an isolated environment where a suspicious file or URL can be detonated safely, revealing its behavior (network calls, file changes, persistence) without touching production systems or real data. A. Upload samples to the SIEM is incorrect. A SIEM aggregates and correlates logs; it is not where malware is executed for dynamic analysis.

Q50: A

C. Pretending is incorrect because it is not a defined social-engineering technique in security terminology. B. Pretexting is incorrect because it centers on inventing a fabricated scenario (a pretext) to justify a request; the deception is the false story rather than acting out another person's identity. A. Impersonation is correct: the attacker masquerades as a real or fictitious person and plays out that person's role on the target. D. Acting is incorrect because it is not a social-engineering attack category.

Q51: D

A. Backup is incorrect. A backup preserves a copy of data for recovery but does not by itself prove the data was unaltered during collection or transfer. D. Hashing is correct. Computing a cryptographic hash of the evidence at collection and comparing it later verifies integrity: any change to the data produces a different hash value, proving it was not modified. C. Encryption is incorrect. Encryption protects the confidentiality of data; it does not demonstrate that the content has remained unchanged. B. Whitelisting is incorrect. Allowlisting controls which applications may run; it has nothing to do with verifying evidence integrity.

Q52: B

B (CSRF) is correct: cross-site request forgery exploits the fact that a browser automatically sends a site's session cookie with every request. When an authenticated user loads a malicious page, that page can silently issue a request to the trusted site, and the site treats it as coming from the user, so the new page effectively inherits the user's identity and privileges. D (SSFR) is incorrect because it is not a recognized attack; the similar-sounding SSRF (server-side request forgery) tricks a server into making requests on the attacker's behalf and does not rely on the user's browser session. C (DLLS) is incorrect because it is not an attack name; DLL injection is a different technique that forces a process to load malicious code. A (DRCR) is incorrect because it is not a recognized web attack.

Q53: C

A. Expense is a reason Arkady could give, so it is not the answer; continuously scanning every system consumes licensing, infrastructure, and staffing resources. B. Workflow interruptions is a reason he could give, so it is not the answer; scans can degrade performance or disrupt production systems while they run. C.A low tolerance for vulnerability risk argues for scanning more frequently, not less, so it would not be a reason to avoid continuous scanning. D. Technical constraints is a reason he could give, so it is not the answer; fragile or legacy systems may not safely support constant scanning.

Q54: D

D. Execute scripted, automated incident responses is correct: in a SOAR platform a playbook codifies a sequence of automated (and sometimes manual) actions that run in response to specific alerts, speeding and standardizing incident handling. A. Track audit trail for password resets is incorrect: that is an IAM logging function, not the role of a SOAR playbook. C. Store backup encryption keys is incorrect: key storage is handled by a key management system or HSM, not a playbook. B. Schedule identity rotations is incorrect: rotating credentials is an identity-management task, unrelated to playbook automation.

Q55: B

D. Insider is incorrect. An insider threat is a current or former employee, contractor, or partner who misuses authorized access; the motivation is typically revenge, financial gain, or negligence rather than a political or social cause. C. Nation-state is incorrect. Nation-state actors are well-resourced groups sponsored by a government, motivated by espionage, war, or strategic advantage rather than activism. B. Hacktivist is correct. A hacktivist is driven by a political or social cause and uses attacks such as website defacement or denial of service to promote or protest that agenda. A. Script kiddie is incorrect. This is an unskilled attacker who relies on prebuilt tools, usually seeking notoriety or thrills rather than advancing a political or social cause.

Q56: C

A. Transfer is incorrect. Transferring risk shifts its impact to a third party (for example insurance or outsourcing) rather than simply accepting it. D. Avoid is incorrect. Avoidance eliminates the risk by not undertaking the activity, not by accepting it. C. Accept is correct. Risk acceptance means the organization acknowledges a known risk and chooses to take no further action, appropriate when its likelihood and impact are low enough to fall within risk tolerance. B. Mitigate is incorrect. Mitigation applies controls to reduce the likelihood or impact of the risk instead of accepting it as-is.

Q57: A

A (Local host file and external DNS server) is correct: name resolution consults the local hosts file first and then the DNS server, so poisoning that hosts file or the external resolver are the two classic DNS attack points Himari has to protect. B (Web server buffer and host DNS server) is incorrect because a web server buffer plays no part in name resolution; only half the pair is DNS-related. C (Reply referrer and domain buffer) is incorrect because neither is a real DNS component; both are invented terms. D (Web browser and browser add-on) is incorrect because those are man-in-the-browser targets: the browser asks the resolver for an answer but is not where DNS resolution happens.

Q58: B

C. Native OS integration is incorrect because the legacy devices in an old plant typically cannot have IPSec support added to their operating systems. A. A hardware security module is incorrect because an HSM safeguards cryptographic keys; it is not a way of implementing IPSec on network traffic. B. Bump-in-the-Wire is correct: a dedicated inline hardware device adds IPSec protection between the legacy equipment and the network without modifying the devices themselves. D. Bump-in-the-Stack is incorrect because it requires inserting IPSec software into each device's network stack, which is impractical across many diverse legacy devices.

Q59: C

C is correct (Directive): a directive control instructs or mandates required behavior, and an acceptable use policy telling employees how to handle data is a classic example. D is incorrect (Preventive): preventive controls stop an event before it happens, such as encryption or a locked door, rather than instruct behavior. B is incorrect (Detective): detective controls identify an event after it occurs, such as log review or an IDS alert. A is incorrect (Corrective): corrective controls restore systems after an incident, such as restoring from backup.

Q60: B

A. Certificate pinning associates a host with an expected certificate or key to resist impostor certificates; it does not query a certificate's revocation status in real time. B. Correct — the Online Certificate Status Protocol (OCSP) performs a real-time lookup of a certificate's status, allowing immediate verification that it has not been revoked. C. Clipping is unrelated to certificate status checking. D. "Remote lookup protocol (RLP)" is not a real protocol for checking certificate status.

Q61: B

B is correct (Non-repudiation): non-repudiation prevents a party from credibly denying an action; a digital signature ties the message to the sender's private key, proving origin. A is incorrect (Authentication): authentication verifies identity at access time but by itself does not create durable proof that a specific message was sent. D is incorrect (Confidentiality): confidentiality keeps data secret from unauthorized parties but does not prove authorship. C is incorrect (Availability): availability ensures resources are accessible when needed and is unrelated to proving who sent a message.

Q62: C

A. Man-in-the-middle is incorrect because an on-path attack intercepts or alters traffic between two parties in transit; the attack described is the takeover of an authenticated session via its token. C. Session hijacking is correct: the attacker steals or reuses a valid session token to take over an authenticated user's active session and impersonate that user. D. Clickjacking is incorrect because it tricks a user into clicking concealed interface elements; it does not seize an active session. B. Buffer overflow is incorrect because it is a memory-corruption application attack and has nothing to do with session takeover.

Q63: A, C

C and A are correct: C (Email with spoofed domain) is correct because it is a classic phishing indicator: attackers forge the sender address or register a look-alike domain so the message appears to come from a trusted bank. A (Suspicious links requesting urgent action) is correct as well, since phishing relies on urgency or fear to push the recipient into clicking a link before thinking. D (Frequent system reboots) is incorrect because unexplained reboots point to unstable software or malware already running on the host, not to a deceptive email. E (Embedded command-line syntax in file name) is incorrect because that indicator relates to malicious file execution on an endpoint rather than to the social engineering message itself. B (IP address conflicts) is incorrect because duplicate IP addresses are a network configuration problem unrelated to phishing.

Q64: C

A. Speeding up browser processing is not a purpose of digital certificates; certificate validation adds overhead rather than reducing it. B. Certificates publish and distribute the public key rather than hide it; a public key is meant to be shared. C. Correct — a digital certificate confirms the true identity of the sender by binding that identity to a public key vouched for by a trusted authority. D. Certificates do not replace digital signatures; the two work together, with signatures relying on the keys that certificates authenticate.

Q65: C

A. Faster recovery time is incorrect. Immutability protects data from modification but does not inherently speed up restores; recovery time depends on backup type, media, and bandwidth. C. Cannot be altered by ransomware is correct. An immutable backup is written once and cannot be changed or deleted for a defined retention period (WORM-style storage), so even if ransomware compromises the environment it cannot encrypt, overwrite, or delete the protected copy, guaranteeing a clean restore point. D. Stored in cold storage is incorrect. Cold storage describes where and how cheaply data is archived; immutable backups can live on hot or cold tiers, so this is not their defining advantage. B. Supports differential compression is incorrect. Compression is a storage-efficiency feature unrelated to immutability, which is about preventing alteration.

Q66: A

A. Threat hunting is correct. It is the proactive search of logs, endpoint telemetry, and network data for malicious activity that automated alerting has not detected. C. Vulnerability scanning is incorrect. It identifies weaknesses and misconfigurations in systems; it does not search for active, undetected intrusions. B. Log archiving is incorrect. Archiving preserves records for later use and compliance; it is storage, not proactive analysis. D. User provisioning is incorrect. It creates and configures user accounts and permissions; it is an identity management task unrelated to searching for threats.

Q67: D

D. SLE (Single Loss Expectancy) is correct. SLE represents the expected monetary loss from one occurrence of a specific risk event, calculated as Asset Value multiplied by Exposure Factor, and feeds into the ALE formula. C. Security awareness training is incorrect. Awareness training is a control, not a quantitative risk metric. B. Business impact analysis is incorrect. A BIA identifies critical functions and the broader impact of outages; it does not represent the loss from a single event. A. Governance framework is incorrect. A governance framework (like COBIT) provides structure for managing IT; it is not a loss-expectancy value.

Q68: C

C (Avoid) is correct: risk avoidance eliminates a risk entirely by discontinuing or never undertaking the activity that creates it. By choosing not to build the data center in an earthquake zone, the organization removes the earthquake exposure altogether, so Giovanni would classify the decision as avoidance. D (Transfer) is incorrect because transferring shifts the financial consequences of a risk to a third party, for example through cyber insurance, while the activity still goes ahead. A (Reject) is incorrect because rejecting a risk is not one of the four recognized risk management strategies (transfer, accept, avoid, mitigate); ignoring a known risk is poor practice, not a formal response. B (Prevent) is incorrect because it is not a Security+ risk strategy term; the closest strategy, mitigation, would mean building the site anyway and adding controls to lower the impact.

Q69: D

D. Ownership is correct. Assigning an owner establishes who is accountable for a hardware, software, or data asset throughout its life cycle. B. Classification is incorrect. Classification labels an asset by sensitivity or criticality; it does not assign accountability to a person or role. A. Inventory is incorrect. An inventory records and tracks assets but does not designate who is answerable for them. C. Sanitization is incorrect. Sanitization removes data from media before disposal or reuse; it is a decommissioning activity, not an accountability assignment.

Q70: 1 = A; 2 = D; 3 = C; 4 = B

EDR matches "Monitors endpoint activity and contains threats" because Endpoint Detection and Response agents continuously record process, file, and network behavior on hosts and can quarantine or isolate them. SOAR matches "Automates incident response playbooks" since SOAR platforms orchestrate multi-tool workflows and run scripted responses with minimal human intervention. SIEM matches "Real-time correlation of security events" because a Security Information and Event Management platform aggregates logs from many sources and correlates them to generate alerts. Firewall matches "Blocks or permits network traffic" as its core function is to enforce allow/deny rules on traffic crossing network boundaries.

Q71: A

A. Manipulating trusted websites to infect a targeted group is correct. In a watering hole attack, the adversary compromises a legitimate website the intended victims are known to visit, so that those specific users are infected when they browse to it. B. Sending malware through watering hole-themed spam is incorrect. Mass spam is a phishing/malspam vector; a watering hole relies on a compromised trusted site, not on themed email. D. Infecting a local DNS cache is incorrect. That describes DNS cache poisoning, which redirects name resolution — a different attack from compromising a website the targets frequent. C. Poisoning a data lake to spread malware is incorrect. Tampering with a data repository is not the watering hole technique, which targets a website used by the victim group.

Q72: C

A. Prevents phishing is incorrect. MFA can reduce the impact of a stolen password, but by itself it does not prevent phishing; users can still be deceived, and some MFA methods can be phished or bypassed. D. Prevents all account lockouts is incorrect. Account lockouts result from lockout policies and failed attempts; MFA does not eliminate them and may add factors that can also fail. C. Reduces reliance on passwords alone is correct. MFA requires an additional factor, something you have or something you are, beyond the password, so a compromised password alone is not enough to gain access. B. Speeds up authentication is incorrect. Adding a second factor generally adds a step to the login process rather than making it faster.

Q73: D

D is correct (Continuous): a continuous risk assessment relies on automated tooling and monitoring to re-evaluate risk in near real time as the environment changes, rather than at fixed points in time. The automatic register updates fed by scanners and the SIEM are its defining feature. B is incorrect (Recurring) because a recurring assessment is repeated on a schedule, quarterly or annually, by people, and between cycles the register is static. A is incorrect (Ad hoc) because an ad hoc assessment is triggered by a specific event or request, such as a new threat report or a management question, and is neither systematic nor automated. C is incorrect (One-time) because a one-time assessment is performed once for a particular project or system, such as before a new application goes live, and is not repeated.

Q74: B

B. SQL injection is correct. SQL injection exploits insufficient input validation by inserting malicious SQL syntax into user-supplied input fields. When the application passes unsanitized input directly to the database, an attacker can manipulate the SQL statement to dump tables, bypass authentication, modify data, or delete records. D. Cross-site scripting is incorrect. XSS injects malicious client-side scripts into web pages viewed by other users — it targets browser sessions, not backend database query logic. A. Buffer overflow is incorrect. A buffer overflow writes more data to a memory buffer than it can hold, potentially enabling code execution — it targets application memory management, not SQL query construction. C. Command injection is incorrect. Command injection inserts OS-level commands into an application to be executed by the system shell — it targets the operating system, not the database engine.

Q75: A

B. Stand-alone (autonomous) AP is incorrect because it stores its own configuration and operates independently, so it cannot be centrally managed by a WLC. A. Controller-based (lightweight) AP is correct because it offloads configuration, roaming, and policy enforcement to the wireless LAN controller and is designed to be deployed and managed in bulk through a WLC. D. Wireless range extender is incorrect because it only rebroadcasts an existing wireless signal; it is not a type of access point managed by a WLC. C. 'Any type of AP can be managed by a WLC' is incorrect because autonomous APs lack controller-management support; only controller-based (lightweight) APs communicate with a WLC.

Q76: D

B. From government contractors working under classified agreements is incorrect because commercial feeds are not built primarily on contractor-supplied or classified data; government-related intelligence typically reaches companies through information-sharing organizations. D. From the information they collect from their own customers is correct: proprietary providers gather telemetry from their subscribers' networks, endpoints, and sensors, then aggregate and anonymize it into their commercial product. A. From free and public sources such as vendor blogs and advisories is incorrect because publicly available data is OSINT, which the question explicitly sets apart from proprietary feeds. C. From paid informants recruited inside criminal forums is incorrect because commercial threat intelligence is driven by technical telemetry collected at scale; human-source reporting is a small adjunct, not the primary input.

Q77: A

D. To conserve power usage is incorrect. Power consumption is an operational concern, not the reason for restricting functionality. A. To reduce the system's attack surface is correct. Least functionality means configuring a system to provide only the capabilities strictly required for its role — disabling unneeded services, ports, accounts and features. Every unnecessary component is a potential attack vector, so removing it shrinks the surface available to an adversary. C. To simplify user access is incorrect. A leaner system may be easier to use, but the driver here is security, not usability. B. To increase DNS query speed is incorrect. Name resolution performance has nothing to do with hardening a host.

Q78: D

B. Group policy configurations are incorrect. Group Policy could explain the lockout threshold, but you first need evidence of what happened; you cannot tell why the account locked without reviewing the logon attempts. C. Time server synchronization is incorrect. Clock skew is a secondary consideration; it does not reveal the source of the failed logons that triggered the lockout. D. Authentication logs are correct. A lockout that occurred while the user was not active points to repeated failed logon attempts (for example, a brute-force attempt or a stale cached credential); the authentication logs show the source, time, and count of those attempts, so they should be examined first. A. File integrity hashes are incorrect. FIM detects changes to files, which is unrelated to why an account was locked out from failed authentications.

Q79: D

D is correct (Accounting): accounting, also called auditing, tracks and logs user activity such as files accessed, commands run, and login times, which is exactly what investigators need. A is incorrect (Authentication): authentication verifies a user's identity at login but does not record what they later did. B is incorrect (Authorization): authorization determines what a user is permitted to access, not a log of their actions. C is incorrect (Attestation): attestation is a claim about a system's integrity or configuration and is not part of the AAA activity-logging function.

Q80: D

B. Confidential is incorrect because in Jan's scheme it sits below the top level; it covers sensitive data whose compromise would be damaging but would not severely impact the enterprise's function and mission. C. Internal is incorrect because it covers data intended for internal use whose compromise would cause only limited impact. D. Critical is correct: it is the highest level in the scheme, reserved for data whose compromise would severely impact the enterprise's function and mission. A. Public is incorrect because it is the lowest level, for information that can be disclosed without harm.

Q81: 1 = A; 2 = B; 3 = D; 4 = C

The correct pairings are: Chain of custody = Tracks evidence handling; Syslog = Standard protocol for log forwarding; Log aggregation = Centralized storage of security events; Log retention = Stores logs for compliance timeframes. Chain of custody documents every person who collected, handled, transferred, or analyzed evidence — essential in legal proceedings to prove evidence integrity. Syslog is the IETF-standard protocol (RFC 5424) allowing devices to send log messages over the network, typically via UDP port 514, to a centralized collector. Log aggregation consolidates logs from firewalls, servers, and endpoints into one platform (often a SIEM) for correlation and analysis. Log retention policies define how long logs must be preserved to satisfy regulations such as PCI DSS (1 year) or HIPAA (6 years).

Q82: A

B. Simulation is incorrect because a simulation puts responders through a realistic, often hands-on emulated incident rather than an informal 30-minute discussion. A. Tabletop is correct because a tabletop exercise is a discussion-based session in which team members talk through their roles and responses to a scenario in an informal, low-stress setting. C. Walkthrough is incorrect because it steps through a specific procedure or plan in detail, not a periodic scenario discussion. D. Relaxed scenario event (RSE) is incorrect because it is not a recognized type of incident-response exercise.

Q83: C

C (Change management) is correct: change management is the structured process that ensures every modification to systems or configurations is reviewed for impact, tested, approved by stakeholders, and documented before it is implemented. This prevents an unapproved or untested change from introducing a vulnerability or outage. D (Incident management) is incorrect because incident management handles the detection, containment, and recovery from security events, not the approval of planned changes. B (Risk management) is incorrect because risk management identifies, assesses, and treats risks at an organizational level; it informs change decisions but does not approve and test specific changes. A (Configuration management) is incorrect because configuration management maintains baselines and records of how systems are set up; it documents the state that change management alters.

Q84: 1 = G; 2 = B; 3 = F; 4 = A; 5 = E

1 → G (Senior manager accountable for a data set who decides its classification and who may access it): the owner holds ultimate accountability for the data and sets the rules for its protection. 2 → B (Entity that determines the purposes and means of processing personal data): the controller decides why and how personal data is processed and carries the primary legal obligations to the data subject. 3 → F (Third party that handles personal data only on the documented instructions of another organization): the processor acts for the controller, for example a SaaS provider running the database, and may not use the data for its own purposes. 4 → A (Technical role that implements backups, permissions, and encryption on behalf of the accountable manager): the custodian or steward operates the day-to-day controls the owner requires but does not decide policy. 5 → E (Identifiable individual whom the personal data is about): the data subject is the person whose privacy rights, such as access or erasure, the other roles must honor. Unused: C (Independent party that tests controls and issues an opinion on whether they operate effectively) — that is an external auditor, not a data role; D (Executive who leads the overall security program and reports to the board) — that is the CISO, a governance role rather than a responsibility for a specific data set.

Q85: 1 = C; 2 = D; 3 = B; 4 = A

The correct mapping is: Heuristic detection identifies threats using generic rule sets and code patterns that suggest malicious intent without matching a known signature — effective against new variants. Signature-based detection uses patterns from known malware samples, providing fast and accurate identification of recognized threats but failing against novel ones. Anomaly-based detection flags deviations from an established behavioral baseline, catching unusual activity even without prior knowledge of the threat. Behavior-based detection evaluates how a process acts over time — if an otherwise legitimate-looking process starts encrypting files or making unusual network calls, it is flagged regardless of its signature.

Q86: B

B. Environmental is correct: environmental physical attacks disrupt the supporting infrastructure an organization depends on, such as electrical power, producing outages like a blackout. A. Brute force is incorrect because, in the physical-attack context, it means forcing entry through doors or barriers, not disrupting utilities. D. RFID cloning is incorrect because it copies access-badge credentials, which is unrelated to a power outage. C. DDoS is incorrect because it is a network attack that overwhelms services with traffic, not a physical attack on power infrastructure.

Q87: B

C. Avoidance is incorrect. Avoidance eliminates the risk by not undertaking the activity at all; here the company keeps the vulnerable test environment running, so it has not avoided the risk. B. Acceptance is correct. Choosing to leave a low-exposure vulnerability unpatched is a deliberate decision to tolerate the risk without further action — the definition of risk acceptance, appropriate when the potential impact is judged low. D. Mitigation is incorrect. Mitigation would reduce the risk by applying a control such as patching or segmentation; the company explicitly decides not to patch. A. Transfer is incorrect. Transfer shifts the financial consequences to a third party (for example via insurance or outsourcing); no such shift occurs here.

Q88: B

C. Detective is incorrect. A detective control identifies that something has gone wrong (e.g., an IDS alert or log review) — disabling a protocol is an active prevention action, not detection. B. Preventive is correct. Disabling SMBv1 removes a known vulnerable protocol from all servers before it can be exploited, directly preventing attacks like EternalBlue/WannaCry from succeeding. This is a hardening action that reduces the attack surface proactively. D. Compensating is incorrect. A compensating control substitutes for a missing primary control — disabling an unnecessary protocol is a direct primary preventive action, not a substitute. A. Physical is incorrect. Physical controls protect the physical environment; disabling a network protocol is a technical, logical control.

Q89: A

B. Rule-based monitoring is incorrect because it triggers on administrator-defined rules and thresholds, not on statistical deviation from a learned baseline. C. Signature-based monitoring is incorrect because it matches activity against known patterns of malicious behavior rather than measuring deviation from normal activity. A. Anomaly-based monitoring is correct: it establishes a statistical baseline of normal behavior and flags activity that deviates significantly from that baseline. D. Heuristic monitoring is incorrect because it applies experience-based rules and approximations to judge whether activity is suspicious, rather than comparing activity against a statistical baseline.

Q90: D

B. Real-time network analytics is incorrect. It observes live traffic as it happens; it does not preserve a suspect system's disk contents for later, repeatable examination. D. Immutable system image is correct. A write-protected, hash-verified image of the suspect system's storage preserves the evidence in its original state, supporting forensic acquisition and preservation and allowing analysis to be repeated offline without altering the source. A. Log rotation schedule is incorrect. Rotation manages log storage over time and can overwrite older entries — the opposite of evidence preservation. C. Automated patch deployment is incorrect. Patching changes system state and serves maintenance, not evidence preservation.